

Mail & Rappels PKI

OLIVIER BLAZY

EMMANUEL CONCHON (EMMANUEL.CONCHON@UNILIM.FR)

1

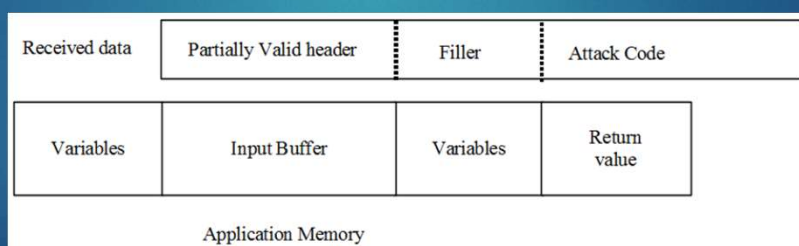
Rappels sur les attaques et vulnérabilités

- ▶ Les attaques et vulnérabilités vont principalement concerner
 - ▶ Les entêtes
 - ▶ Les protocoles
 - ▶ La phase d'authentification
 - ▶ Le trafic (DOS, Sniffing...)
- ▶ Certaines attaque sont communes mais la majorité ne touchent qu'un seule type d'application
 - ▶ Un bémol pour les attaques visant les droits additionnels

2

Les attaques sur les entêtes

- ▶ Ce sont des attaques fréquentes sur les applications
 - ▶ La plupart des applications ont des entêtes libres qui doivent être parsés correctement
 - ▶ Possibilité de s'en servir pour générer des buffer overflows (débordement de mémoire)



3

Protocoles et authentification

- ▶ Les attaques protocolaires sont spécifiques à chaque application
 - ▶ Souvent un pré requis aux attaques d'authentification
- ▶ Les attaques d'authentifications sont les plus répandues et peuvent être de deux types
 - ▶ Directe: Se servir de l'application pour découvrir un mot de passe
 - ▶ Indirecte: tente de contourner l'authentification
- ▶ Dans le cadre de ce cours nous nous intéresserons principalement aux protocoles Mail
 - ▶ SMTP, POP/IMAP, MIME

4

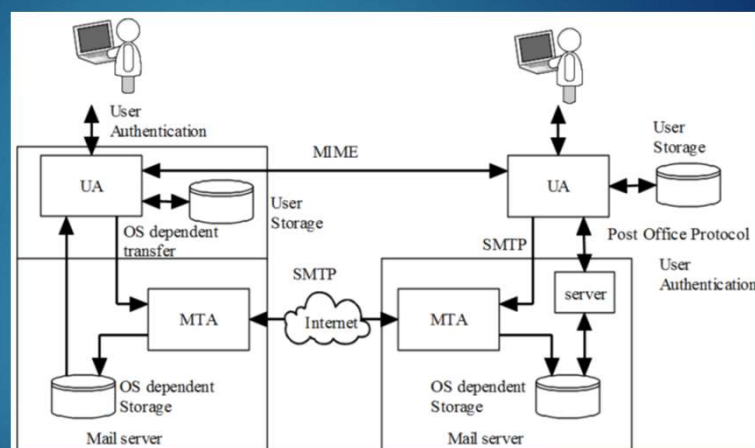
Rappels sur le Mail

- Un système de mail électronique fournit 4 fonctions :
 - **Création** : Un utilisateur crée et édite un message
 - **Envoie** : L'utilisateur désigne un (ou des) destinataires, et le système envoie le message aux boîtes appropriées
 - **Réception** : Le destinataire désigné peut demander au système de mail d'accéder et de lire les messages
 - **Stockage** : L'expéditeur et le destinataire peuvent conserver une copie

5

Rappels sur le mail

- UA/MUA: (Mail) User Agent
- MTA: Mail Transfert Agent



- MDA: Mail Delivery Agent



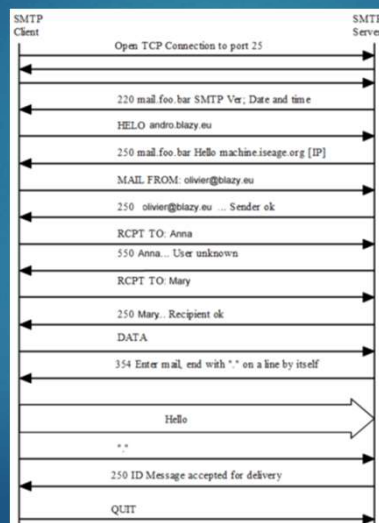
6

SMTP (Simple Mail Transfert Protocol)

- ▶ SMTP est un standard pour transmettre des mails définit dans la RFC 821 et clarifié dans MIL-STD-1781
- ▶ Il ne définit pas le format ou le contenu des messages sauf :
 - ▶ Ils doivent être encodés sur du 7 bit ASCII
 - ▶ Il ajoute des informations qui indiquent le chemin parcouru
- ▶ Le protocole essaye d'être fiable, mais il ne prévoit rien
 - ▶ Si les hôtes perdent les fichiers
 - ▶ S'ils ne donnent pas d'accusé de réception si le message est reçu,
 - ▶ Pour retourner obligatoirement les erreurs
- ▶ Il ne comporte que de simples commandes (14)

7

SMTP (Simple Mail Transfert Protocol)



8

Les principales attaques sur SMTP

- ▶ Les attaques sur les en-têtes sont en général peu fréquentes à l'heure actuelle
 - ▶ Peuvent encore arriver sur de vieilles implémentations pour du buffer overflow
- ▶ Les attaques protocolaires sont assez difficiles à mettre en œuvre sur des protocoles basés sur des commandes/réponses
 - ▶ Les commandes reçues dans le désordre sont considérées comme des erreurs et ne sont pas traitées
 - ▶ Le plus courant sont les connexions multiples qui peuvent agir comme un déni de services côté serveur et ralentir son fonctionnement

9

Les principales attaques sur SMTP

- ▶ Les plus fréquentes sont les attaques par authentification
 - ▶ Il n'y a pas d'authentification en SMTP
 - ▶ Entraîne de nombreux problèmes de Spam et de phishing
- ▶ Les attaques basées sur le trafic sont également nombreuses
 - ▶ Déni de service des serveurs
 - ▶ Utilisation des fonction de « Reply To: » pour faire du déni de service distribué
 - ▶ Des messages trop gros ralentissent aussi les serveurs
 - ▶ Sniffing

10

POP (Post Office Protocol)

- ▶ POP est un protocole de transferts de mails entre un client et un serveur (RFC 1939)
 - ▶ Il fournit également un mécanisme d'authentification
- ▶ Déroulé d'une session POP:
 - ▶ Un client POP3 se connecte à un serveur POP3
 - ▶ Login et mot de passe en clair
 - ▶ L'utilisateur peut configurer à quelle fréquence les mails sont vérifiés (et donc combien de fois le mot de passe est transmis)

11

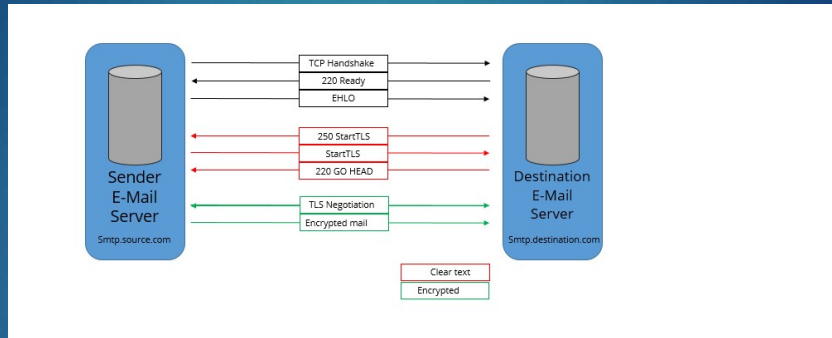
IMAP

- ▶ Permet de récupérer et classer les messages
- ▶ POP, ne fonctionne pas très bien avec plusieurs clients comme les mails sont supprimés une fois lus
 - ▶ IMAP peut les garder sur le serveur et propager ses modifications entre les clients

12

Contremesures

- ▶ STARTTLS permet de faire que SMTP utilise TLS (trafic chiffré)

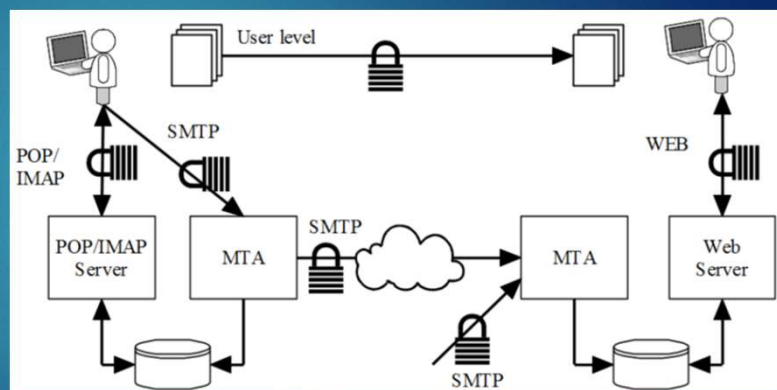


- ▶ SMTP-Auth est une extension qui permet à l'utilisateur de s'authentifier (RFC4954)
- ▶ Leur adoption pourrait réduire le spam

13

Contremesures

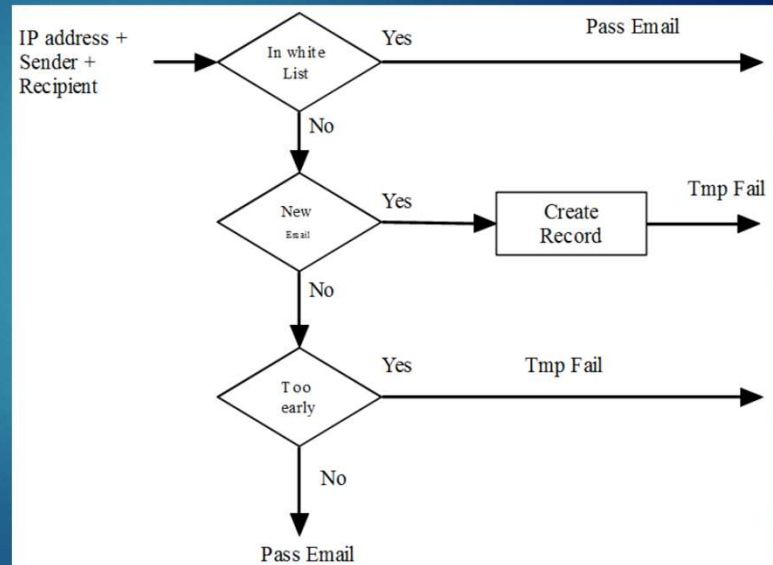
- ▶ Chiffrement et authentification
- ▶ Filtrage d'email
- ▶ Filtrage du contenu
- ▶ Forensics des E-mails



14

Contremesures

- ▶ Filtres
 - ▶ Spam (Intelligent, évolutif)
 - ▶ Listes (blanches noires, grises)



15

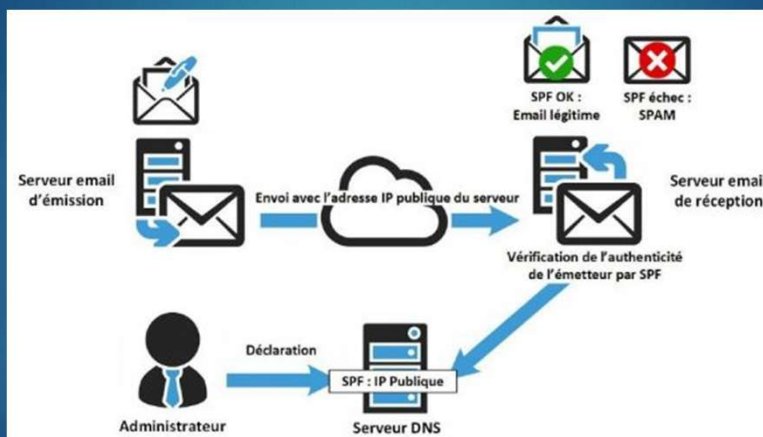
SPF (Sender Policy Framework)

- ▶ RFC7208
- ▶ Processus d'authentification permettant de vérifier la conformité de l'expéditeur d'un mail
 - ▶ Indique qui a le droit d'utiliser votre nom de domaine en listant les Ips destinées à envoyer des mails
 - ▶ Il évalue l'identité fournie par le MAIL FROM de la session SMTP
- ▶ Exemple du site ietf.org obtenue avec la commande « dig TXT ietf.org »

```
;; ANSWER SECTION:
ietf.org. 1745 IN TXT "v=spf1 ip4:4.31.198.32/27 ip6:2001:1900:3001:0011::0/64 ip4:66.70.182.38 ip4:158.69.166.16/29 ip6:2607:5300:203:1b26::0/64 ip4:158.69.229.207 ip4:192.95.54.40/29 ip6:2607:5300:0060:9ccf::0/64 " "include:_spf.google.com -all"
```

16

SPF (Sender Policy Framework)



Source:
<https://blog.devensys.com/spf-dkim-dmarc-securite-mail/>

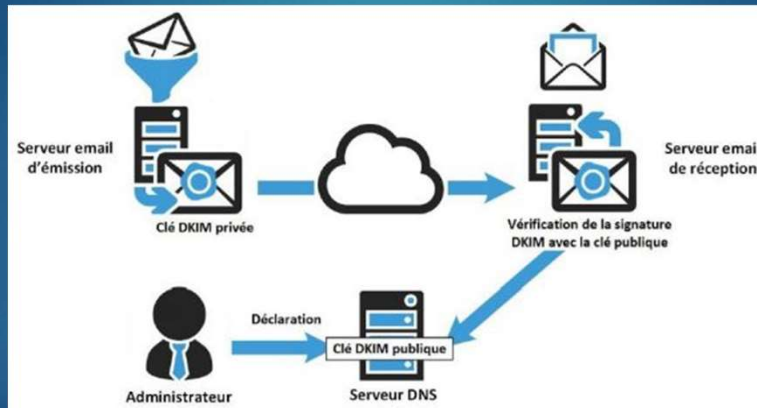
17

DKIM (DomainKeys Identified Mail)

- ▶ Défini dans la RFC 6376, elle permet d'authentifier de manière fiable le nom de domaine de l'émetteur d'un mail
- ▶ Repose sur des signatures électroniques
 - ▶ Du corps du message
 - ▶ D'une partie des en-têtes pour sécuriser le nom de domaine de l'expéditeur
 - ▶ Cette signature est indépendante de celle du rédacteur du message
- ▶ DKIM permet d'assurer 3 choses
 - ▶ Le contenu d'un email n'a pas subi de modifications
 - ▶ Les en-têtes de l'email n'ont pas changé pendant l'envoi
 - ▶ il n'y a pas de nouveau domaine « de » ajouté
 - ▶ L'expéditeur du mail possède le domaine DKIM correspondant ou est autorisé par le propriétaire

18

DKIM (DomainKeys Identified Mail)



Source:
<https://blog.devensys.com/spf-dkim-dmarc-securite-mail/>

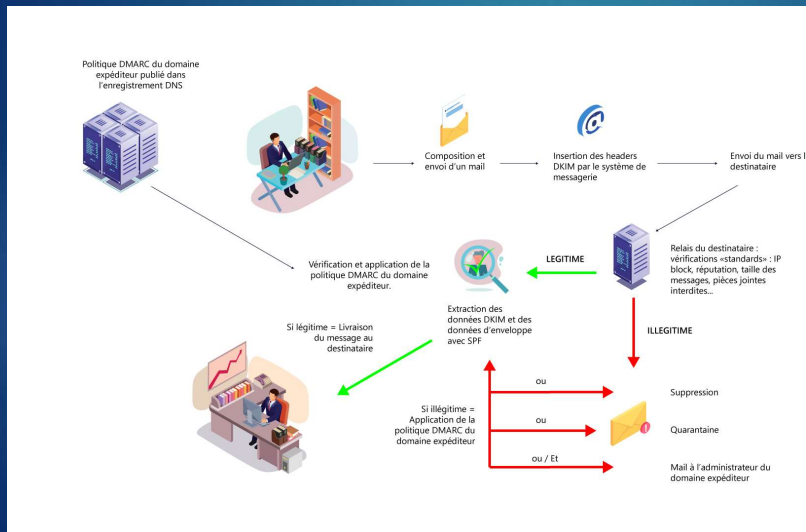
19

DMARC (Domain-based Message Authentication, Reporting and Conformance)

- ▶ RFC 7489
- ▶ DMARC a pour objectif de standardiser la manière d'utiliser SPF et DKIM par les MTA
- ▶ Il permet également de faire de la surveillance de l'authentification et des problèmes qui y sont liés
- ▶ Les politiques DMARC sont publiées dans le DNS public du domaine comme enregistrement TXT
 - ▶ Elles annoncent ce que le destinataire d'un courriel doit faire si ce dernier ne satisfait pas les mécaniques d'authentification SPF et/ou DKIM.

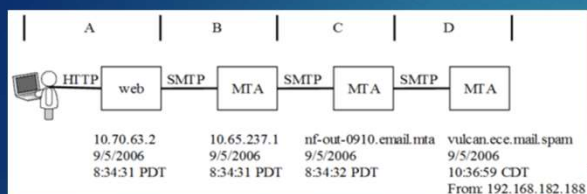
20

DMARC



Source:
<https://blog.devensys.com/spf-dkim-dmarc-secure-mail/>

21



```

Received: from nf-out-0910.email.mta (nf-out-0910.email.mta
[192.168.182.188])
  by vulcan.ece.mail.spam (8.12.8/8.9.3) with ESMTP id
  k85FaxBT1486661
  for <john@ee.mail.spam>; Tue, 5 Sep 2006 10:36:59 -0500 (CDT)
Received: by nf-out-0910.email.mta with SMTP id p77so138135nfc
  for <john@ee.mail.spam>; Tue, 05 Sep 2006 08:34:32 -0700 (PDT)
DomainKey-Signature: a=rsa-sha1; q=dns; c=noews;
s=beta; d=spammer.fake;
h=received:message-id:date:from:to:subject:mime-
version:content-type;
b=BD9tHbNaozYZj9gNqQXmkrrnHNA3N8+3W4NApcFJKsKyX8DdOTS7Dp1VNunGx66SLcU5r
YiDxCnY6SuVCktWq73DDH7MYEfWgaOtydl/hILIRVnCbLxGtyCoIT7I8use4F4RgCzZWc3
Oc6fjgNzgGLE5s3RFQ9eVPhS+HxW+DA=
Received: by 10.65.237.1 with SMTP id o1mr4809264qbr;
  Tue, 05 Sep 2006 08:34:31 -0700 (PDT)
Received: by 10.70.63.2 with HTTP; Tue, 5 Sep 2006 08:34:31 -0700 (PDT)
Message-ID:
<ab156e9f0609050834v528b5b2eld9204458fe6409a1@mail.spammer.fake>
Date: Tue, 5 Sep 2006 10:34:31 -0500
From: "Harry Mudd" <Harry6502@spammer.fake>
To: john@ee.mail.spam
Subject: mail trace 2
MIME-Version: 1.0
  
```

22

Les architectures PKI

23

23

Bibliographie

24

- ▶ « Principles of Computer Security: CompTIA, Security+ and Beyond », Second Edition, McGraw-Hill editor
 - ▶ La plupart des schémas utilisés dans ce support sont tirés de cet ouvrage
- ▶ « Cryptography and Network Security Principles and Practice, 5th Edition », William Stallings

24

Le problème de l'échange des clés publiques

25

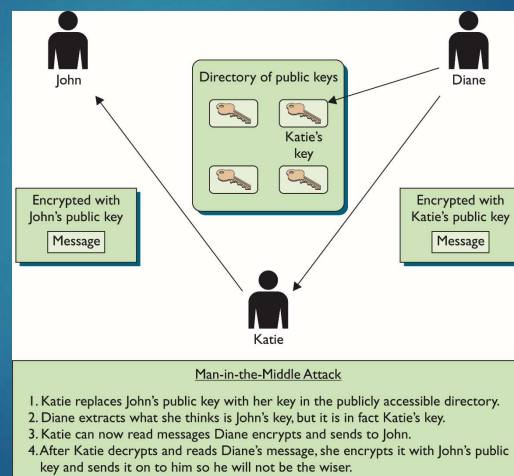
- ▶ Dans une architecture publique, la prise en compte des clés publiques nécessite d'avoir confiance dans la personne qui nous la fournit
- ▶ L'obtention de la clé publique peut se faire
 - ▶ Soit par envoi en point en point (ex GPG) entre deux entités
 - ▶ Soit en passant par un annuaire centralisé comme LDAP par exemple
- ▶ Dans les deux cas, il faut s'assurer que la clé que l'on récupère provient bien de la personne concernée
 - ▶ Pas de garanties !

25

Le problème de l'échange des clés publiques

26

- ▶ Attaque « Man In the Middle »



Source:
« Principles of
computer
security »,
McGraw-Hill

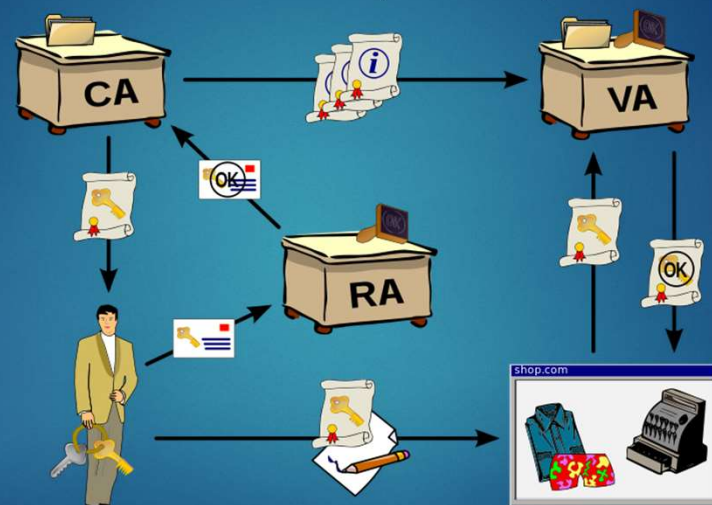
26

L'infrastructure à clés publiques

- ▶ L'objectif d'une PKI est de fournir des tiers de confiance partagés par Alice et Bob
- ▶ Une PKI va être composée de plusieurs éléments
 - ▶ Des certificats électroniques
 - ▶ Des autorités pour
 - ▶ L'enregistrement : Registration Authority ou RA
 - ▶ Va stocker et valider les clés publiques
 - ▶ La certification: Certification Authority ou CA
 - ▶ Emet le certificat à partir d'une clé publique validée par une RA
 - ▶ Communique le certificat aux VA
 - ▶ La validation: Validation Authority ou VA
 - ▶ Assure la validité d'un certificat
 - ▶ Un protocole standardisé de vérification

27

L'infrastructure à clés publiques (PKI)



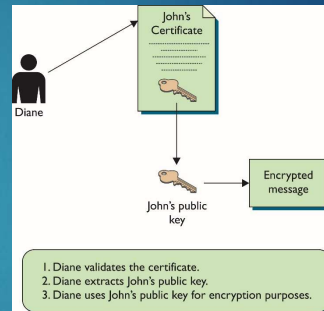
28

Le certificat

- ▶ Un certificat va jouer le rôle d'une carte d'identité numérique de la clé publique

- ▶ Il contient

- ▶ L'identité de la personne
- ▶ La clé publique de cette personne
- ▶ Une attestation de cette association par un tiers de confiance



29

Source:
« Principles of
computer
security »,
McGraw-Hill

29

Le certificat

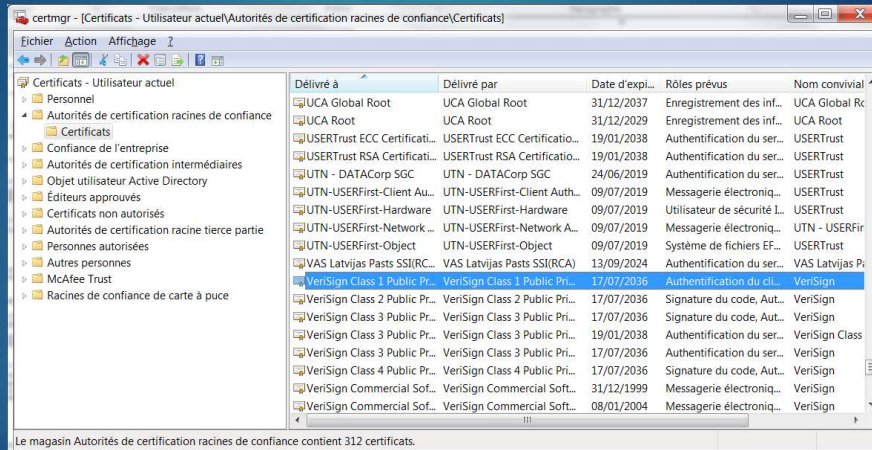
- ▶ La clé publique de l'autorité est ensuite largement diffusée
 - ▶ Elle peut également être signée par une autre autorité
 - ▶ On parle alors de chaîne de confiance
 - ▶ La confiance est alors accordée si dans la chaîne on trouve une autorité dans laquelle on a confiance
 - ▶ VeriSign
 - ▶ GTE
 - ▶ Certinomis
 - ▶ ...
- ▶ La confiance dans la PKI repose donc sur la confiance que l'on accorde aux autorités associées
 - ▶ Par défaut les systèmes d'exploitations et les navigateurs Web disposent de clés publiques d'autorités « de confiance »

30

30

Le certificat

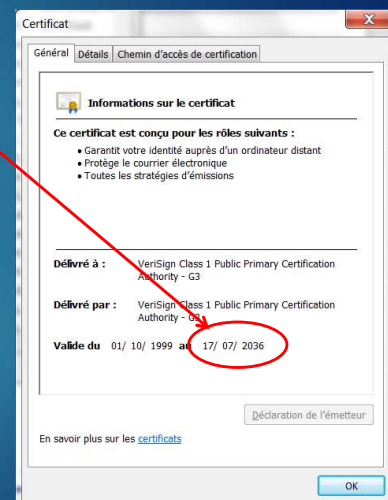
- Sous Windows (certmgr.msc)



31

Le certificat

- Un certificat est doté d'une date d'expiration
 - Cette date peut être très éloignée
 - Que ce passe-t-il si l'autorité disparaît entre temps?
 - Ces certificats doivent pouvoir être révoqués
- L'autorité de certification doit donc
 - délivrer des certificats
 - leur donner une date de validité
 - pouvoir les révoquer
 - en particulier si sa clé est compromise



32

Les certificats

- ▶ On distingue trois classes de certificats
- ▶ Les certificats de classe 1 associent une clé publique à une adresse e-mail
 - ▶ Le demandeur reçoit un mail de confirmation
 - ▶ Pas de contrôle supplémentaire de la véracité de l'identité
 - ▶ Permet la signature et le chiffrement de courrier électronique essentiellement
 - ▶ Peuvent s'obtenir très rapidement et souvent gratuitement (Verisign et StartSSL)
 - ▶ Utilisation dans un cadre personnel
- ▶ Les certificats de classe 2 offrent les mêmes fonctionnalités que les classes 1
 - ▶ Vérification plus poussée de l'identité pouvant aller jusqu'à la présentation physique
 - ▶ Permettent de faire de la signature d'application logicielle
 - ▶ Permet de garantir l'identité de l'éditeur du logiciel
 - ▶ Utilisés dans le cadre professionnel

33

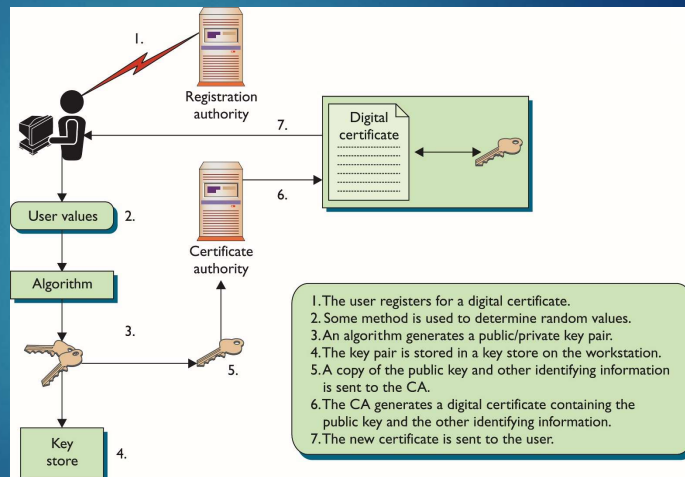
Les certificats

- ▶ Les certificats de classe 3 sont les certificats de plus haut niveau
 - ▶ Vérification de toutes les informations fournies
 - ▶ Compensation financière en cas de litige
 - ▶ Les certificats de classe 3 permettent également de mettre en œuvre sa propre autorité de certification pour émettre des certificats
 - ▶ L'entité devient alors une LRA (local registration authority)
 - ▶ Si la LRA n'appartient pas à une chaîne de confiance, elle émet des certificats auto-signés
 - ▶ Utile pour certifier des éléments au sein d'une entreprise avec plusieurs sites
- ▶ Une CA reconnue doit être plus qu'un simple logiciel
 - ▶ Il faut des moyens humains pour vérifier les informations
 - ▶ Elle doit fournir un CPS: Certification Practice Statement qui précise
 - ▶ la manière dont les informations sont vérifiées
 - ▶ les étapes suivies et les données utiles pour produire un certificat
 - ▶ La manière de révoquer un certificat

34

L'obtention d'un certificat

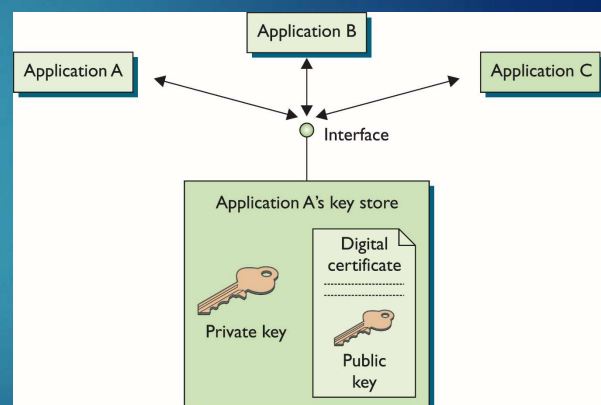
- Pour obtenir un certificat on passe par une Registration authority (RA)
- La RA peut également être une CA mais ce n'est pas obligatoire



35

L'obtention d'un certificat

- Une fois obtenu le certificat peut être stocké localement dans un « Key store »
 - Le « key store » est une base de donnée locale accessible par les applications à travers une API dédiée
- Quelques exemple de « Key Store »
 - PKCS#11 sous Unix
 - CAPI (Crypto API) sous Windows
 - JCA (Java Crypto API) en Java
- Dans un réseau local au utilisera un annuaire LDAP



36

Le contenu d'un certificat

37

- ▶ Le format des certificats est défini par l'IETF à travers le standard X.509
 - ▶ Retenu par l'ITU-T comme standard international pour assurer l'interopérabilité des systèmes à base de certificats
- ▶ Actuellement on utilise la version 3 des certificats X.509 [RFC 5280]
 - ▶ Issuer caractérise la CA
 - ▶ Subject le propriétaire
 - ▶ Gestion des extensions
- ▶ Les noms sont représentés grâce au DN (Distinguished Name) de X.500
 - ▶ Egalement utilisé dans LDAP

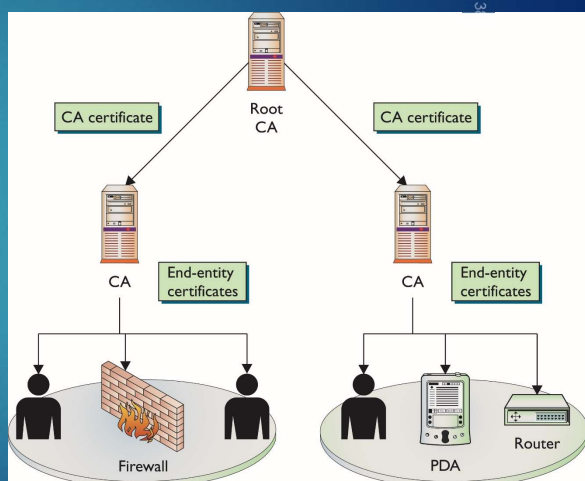
Version	version 1	version 2	version 3		
Serial Number					
Signature Algorithm Identifier					
Issuer Name					
Validity Period					
Subject Name					
Public Key Information					
Issuer Unique ID					
Subject Unique ID					
Extensions					

37

Des certificats pour tout le monde

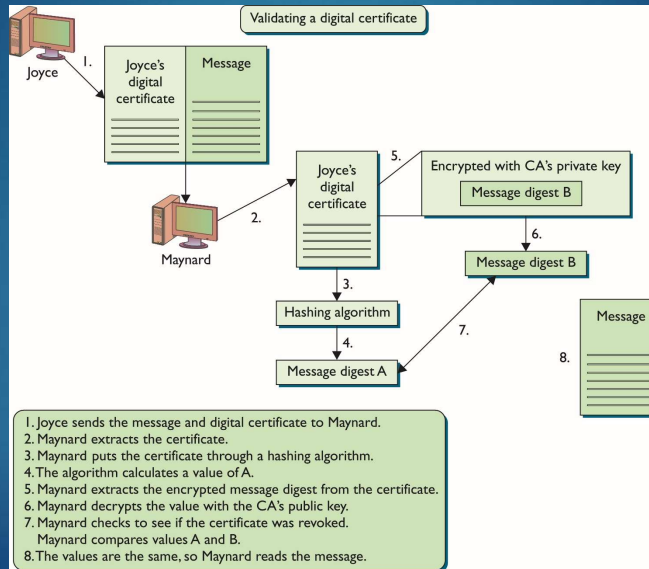
38

- ▶ Les certificats ne sont pas limités à des personnes physiques ils peuvent aussi identifier
 - ▶ Une CA
 - ▶ Des CA intermédiaires
 - ▶ Des matériels
 - ▶ Des utilisateurs
 - ▶ Des applications



38

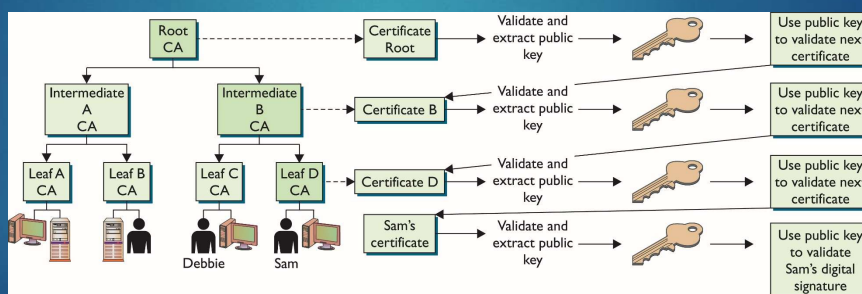
La validation d'un certificat



39

La validation d'un certificat

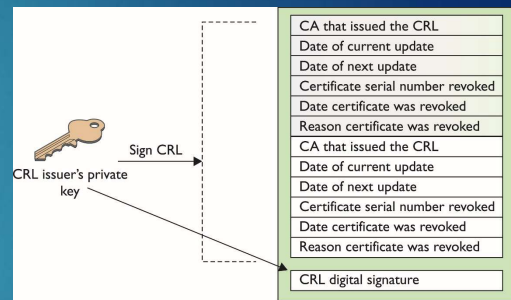
- La validation d'un certificat nécessite de valider la chaîne de confiance
- Exemple pour une architecture hiérarchique



40

La validation d'un certificat

- ▶ La vérification se passe en plusieurs étapes
 - ▶ On vérifie en premier lieu que le certificat n'a pas expiré
 - ▶ On authentifie ensuite l'empreinte avec la clé publique de la CA
 - ▶ On vérifie l'intégrité du certificat
 - ▶ Puis, on vérifie que le certificat n'a pas été révoqué en consultant la liste des révocations de certificats (CRL) de la CA
- ▶ Pour chaque entrée de la CRL on peut connaître la cause de la révocation ainsi que la date à partir de laquelle il n'est plus valable



41

La validation d'un certificat

- ▶ Les CRL peuvent donc être vues comme des listes noires de certificats
 - ▶ En fonction du code, la gravité de la révocation va varier

Reason Code	Reason
0	Unspecified
1	All keys compromised; indicates compromise or suspected compromise
2	CA compromise; used only to revoke CA keys
3	Affiliation changed; indicates a change of affiliation on the certificate
4	Superseded; the certificate has been replaced by a more current one
5	Cessation; the certificate is no longer needed, but no reason exists to suspect it has been compromised
6	Certificate hold; indicates the certificate will not be issued at this point in time
7	Remove from CRL; used with delta CRL to indicate a CRL entry should be removed

42

Et la clé privée alors ?

- ▶ La clé privée doit rester la propriété exclusive de son propriétaire
 - ▶ Elle ne doit normalement jamais être communiquée
 - ▶ Elle ne doit pas être copiée
 - ▶ Elle doit être stockée en étant chiffrée par un algorithme symétrique
 - ▶ Le couple (clé publique, clé privée) doit avoir une durée de vie et pouvoir être révoqué

- ▶ Mais alors comment faire lorsque
 - ▶ L'utilisateur perd sa clé ?
 - ▶ Lorsqu'il est absent et que sa hiérarchie doit avoir accès à certains documents ?
 - ▶ En cas de décision de justice ordonnant la divulgation de certaines données ?

43

43

L' autorité de séquestre

- ▶ L'autorité de séquestre (Key Escrow) est une entité chargée de conserver les informations secrètes comme les bi-clés
 - ▶ Permet d'avoir accès aux échanges et/ou information d'une personne dans le cadre de son travail

- ▶ L'autorité de séquestre est un élément très important d'un PKI car il doit absolument maintenir la confidentialité des données
 - ▶ Soulève des contraintes à la fois techniques mais aussi légale

- ▶ Un moyen pour simplifier l'utilisation d'une autorité de séquestre est d'utiliser plusieurs couples de clés
 - ▶ Un couple sert pour le chiffrement des données
 - ▶ Un autre couple pour la signature

44

44

Les limites de PKI

- ▶ La révocation des certificats n'est pas optimale
 - ▶ Actuellement le système se base sur des listes noires qu'il faut sans cesse réactualiser
 - ▶ Une meilleure solution consisterait à utiliser des listes blanches
- ▶ Tout repose sur la chaîne de confiance
 - ▶ Si les CA sont compromises le système flanche
 - ▶ Si trop de faux certificats sont émis la confiance va disparaître
 - ▶ L'utilisateur n'est que rarement acteur du système (les certificats sont gérés par son navigateur ou son système)
- ▶ Les CA sont toutes des entreprises privées
 - ▶ Elles se financent sur l'émission de certificat pas sur les vérification
 - ▶ Que se passe-t-il en cas de faillite ? En cas d'acquisition ?
 - ▶ Les certificats ont des durées de vie très longue que faire dans ce cas ?

45